

Rapport de Projet : Infrastructure de Commandement et Contrôle (C2) Résiliente

Pour l'Émulation d'Adversaires Avancés (APT)

Opérations Red Team - MAROUANI Taha

Année Académique 2025–2026

Table des matières

1	Sommaire Exécutif et Justification du Projet	3
1.1	Objectif du Projet et Nécessité	3
1.2	Émulation d'Adversaire vs. Simulation	3
2	Principes Fondamentaux et Architecture Technique	3
2.1	Le Concept de Commandement et Contrôle (C2)	3
2.2	Architecture : Le Modèle Défensif Multi-Couche	3
3	Détails Techniques et Composants Clés	4
3.1	Couche A : Infrastructure as Code (IaC) et Résilience	4
3.2	Couche C : Le Filtre de Redirection Nginx	4
3.3	Couche D : Le Cœur C2 (Haute Sécurité)	4
3.4	Couche E : Leurre et Alerte OPSEC	4
4	Outils et Techniques d'Émulation Avancée	4
4.1	Simulateurs de Menace Spécifiques	4
4.2	Sécurité des Domaines	5
5	Conclusion et Valeur Ajoutée pour l'Organisation	5
5.1	Points Clés et Retombées	5

1 Sommaire Exécutif et Justification du Projet

Ce document présente l'architecture d'une infrastructure de **Commandement et Contrôle (C2)** conçue pour des exercices d'**émulation d'Adversaire** de haute fidélité. L'objectif est de tester nos défenses contre les menaces les plus sophistiquées (Groupes **APT**).

1.1 Objectif du Projet et Nécessité

Les attaquants modernes ne se contentent pas d'exploiter des failles ; ils construisent des réseaux complexes pour **maintenir l'accès** et **chapper la détection**. Ce projet a été initié pour :

- ✓ **Augmenter le Réalisme** : Simuler les techniques (TTPs) exactes utilisées par des groupes de menace de niveau étatique ou criminel avancé.
- ✓ **Assurer la Résilience** : Permettre à l'équipe Red Team de continuer l'exercice même après que des composants initiaux de l'attaque aient été détectés par l'équipe de défense (Blue Team).

1.2 Émulation d'Adversaire vs. Simulation

Il est crucial de noter qu'il s'agit d'**émulation d'Adversaire**, et non d'une simple simulation.

- **Simulation** : Tester de manière générique les contrôles de sécurité.
- **Émulation** : Reproduire fidèlement le comportement d'un groupe d'attaque **spécifique** et connu (ses outils, ses protocoles et sa capacité à réagir à la défense). Notre infrastructure supporte ce niveau de réalisme.

2 Principes Fondamentaux et Architecture Technique

2.1 Le Concept de Commandement et Contrôle (C2)

Le C2 est la liaison de communication secrète entre l'attaquant et l'appareil compromis.

- **Analogie du Sous-Marin** : Si le code malveillant implanté est un **sous – marin** opérant dans le réseau cible, le **serveur C2** est la base distante qui envoie des ordres et reçoit les données sans être détectée par le sonar.
- **Pourquoi "C2" ?** Ce terme est utilisé par les services de renseignement pour désigner la **fonction exécutive** du système d'attaque (donner des ordres et contrôler les opérations).

2.2 Architecture : Le Modèle Défensif Multi-Couche

L'architecture est construite selon un modèle de **Défense en Profondeur** (analogie de l'oignon), où la ressource la plus précieuse (le C2 Core) est protégée par plusieurs couches de filtrage.

- ▷ **Couche A (IaC)** : Automatisation du déploiement.
- ▷ **Couche C (Redirecteur)** : Filtrage de trafic public.
- ▷ **Couche D (C2 Core)** : Cœur de l'opération (Haute Valeur).
- ▷ **Couche E (Leurre)** : Piège à analyste et déclencheur d'alerte.

3 Détails Techniques et Composants Clés

3.1 Couche A : Infrastructure as Code (IaC) et Résilience

L'infrastructure n'est pas construite manuellement ; elle est définie dans du code, garantissant la cohérence et la vitesse.

- **Outils : Terraform** (pour le déploiement des serveurs et réseaux cloud) et **Ansible** (pour la configuration logicielle, e.g., Nginx).
- **Mécanisme : Burn and Rebuild (Brûler et Reconstruire)** : En cas de détection, le code permet d'exécuter un script qui **dtruit** instantanément les serveurs frontaux exposés et en **redploie** de nouveaux avec des adresses IP et des noms d'hôtes différents, garantissant la **continuité de l'opération**.

3.2 Couche C : Le Filtre de Redirection Nginx

Cette couche est le point de contact public et le premier niveau de sécurité.

- **Technologie : Nginx** (utilisé comme proxy inverse).
- **Logique d'Évasion** : Le serveur Nginx examine chaque requête web et ne la transmet au C2 Core que si elle contient un **en-tête HTTP secret et personnalisé**.
- **Trafic Non Valide** : Tout scanner, crawler, ou analyste ne connaissant pas cet en-tête secret est **redirigé silencieusement** vers le Leurre (Couche E).
- **Amélioration Avancée** : Utilisation du **CDN Fronting** (via des services comme AWS CloudFront) pour masquer la véritable adresse IP du Redirecteur, intégrant le trafic malveillant dans le flux massif des grands réseaux de distribution de contenu.

3.3 Couche D : Le Cœur C2 (Haute Sécurité)

- **Principe de Sécurité : Zéro Confiance (Zero Trust)** : Le pare-feu du serveur C2 Core est configuré pour **TOUT bloquer** par défaut.
- **Liste Blanche** : L'accès est **strictement limité** aux adresses IP des **Redirecteurs actifs** de la Couche C. Cela garantit qu'aucune entité externe (même si le Redirecteur est compromis) ne peut communiquer directement avec le Core, le rendant **indétectable de l'extérieur**.

3.4 Couche E : Leurre et Alerte OPSEC

- **Fonction : Piège à Canari (Canary Trap)** : Ce serveur dédié est le point de chute final pour tout trafic non autorisé. Il sert une page web banale (e.g., une page d'erreur standard) pour ne pas éveiller les soupçons.
- **Déclenchement d'Alerte : Toute connexion** à ce serveur est considérée comme une détection potentielle et déclenche **immédiatement une alerte prioritaire** (via webhook Slack ou autre) à l'équipe Red Team. Cette alerte permet d'amorcer l'opération de **Burn and Rebuild** avant que les défenseurs n'aient le temps d'agir.

4 Outils et Techniques d'Émulation Avancée

4.1 Simulateurs de Menace Spécifiques

- ◇ **Evilginx (MFA Bypass)** : Outil utilisé pour simuler les attaques sophistiquées qui **contournent l'authentification** en volant le jeton de session post-authentification.

- ◇ **Gophish** : Plateforme utilisée pour la gestion et le suivi des campagnes de phishing à grande échelle.

4.2 Sécurité des Domaines

- ◇ **DNStwist et URLCrazy** : Outils utilisés en amont pour générer des domaines de phishing visuellement très convaincants, incluant des techniques de **Homoglyphes** (**caractres similaires** **prove**) pour tromper l'œil de l'utilisateur.
- ◇ **Vérifications de Santé Automatisées** : Des scripts exécutent des requêtes régulières auprès de services de renseignement sur les menaces (**API Google Safe Browsing**) pour confirmer que les domaines actifs ne sont pas répertoriés sur des listes noires, assurant ainsi une **proactivité OPSEC**.

5 Conclusion et Valeur Ajoutée pour l'Organisation

5.1 Points Clés et Retombées

1. **Amélioration de la Défense** : L'utilisation de cette infrastructure force nos équipes de sécurité (Blue Team) à **déceler des menaces de niveau APT**, améliorant ainsi de manière significative nos capacités de détection les plus avancées.
2. **Professionnalisme (Gouvernance)** : La gestion de l'infrastructure par **Infrastructure as Code** assure que tous les composants d'attaque sont **documentés, reproductibles et conformes** aux exigences d'audit et de gouvernance.
3. **Efficacité Opérationnelle** : Le cycle de **Burn and Rebuild** réduit le temps de réaction aux incidents, permettant à l'équipe Red Team de maximiser le temps passé sur l'émulation, et non sur l'administration des serveurs.